

Penetration Test Report

Hospital Management Web Application

Vulnerable vs Secure Version Comparison

1. Executive Summary

A penetration test was conducted on the Hospital Management Web Application to evaluate the security posture of two versions:

- Vulnerable Version (Original Development Build)
- Secure Version (Patched & Enhanced Build)

The vulnerable version exposed critical weaknesses that could lead to full system compromise, unauthorized medical data tampering, appointment manipulation, and SQL database extraction. After applying security fixes, the secure version demonstrated significant improvements, closing all critical vulnerabilities and aligning with best practices for healthcare applications.

2. Scope of Work

In-Scope Components

- Patient Profile Management
- Appointment Booking System
- Doctor Information Module
- Authentication/Session Management
- Backend API Endpoints
- Database interactions (MySQL)
- Form handling & hidden fields

Testing Methodology

- OWASP Web Security Testing Guide (WSTG)
- Manual Black-Box & Gray-Box testing
- Input manipulation (Burp Suite, Postman)
- Business logic abuse
- Race condition testing
- SQL payload injection

3. Summary of Findings

Vulnerability	Vulnerable System	Secure System
Error/Stack Trace Disclosure	Present	Fixed (buried & logged only)
Hidden Field Manipulation	Present	Fixed
IDOR (doctor_id manipulation)	Present	Fixed (server-side validation)
Time-Based SQL Injection	Present	Fixed (prepared statements)
Race Condition Booking Overflow	Present	Fixed (backend request locking)
Missing Required Field Validation	Present	Fixed
Foreign Key Integrity Errors	Present	Fixed
XSS Injection Points	Present	Fixed

4. Detailed Findings

4.1 Time-Based Blind SQL Injection (Critical)

Location: appointments.php → parameter doctor_id

Description: The backend did not use prepared statements when processing the doctor_id during appointment creation. This allowed attackers to inject time-based payloads by intercepting the POST request.

Proof of Concept (PoC):

Injected payload:

14' OR IF(1=1, SLEEP(5), 0) --

- Normal response: 200 ms
- Malicious response: 5+ seconds

This confirms a valid time-based blind SQL injection.

Impact:

- Database extraction via blind techniques
- Unauthorized data modification
- Full system compromise potential

Status in Secure Version:

- Parameterized queries used
- Server discards malformed values
- No timing difference detected

→ Vulnerability eliminated

4.2 Full Error & Path Disclosure (High)

Evidence: The vulnerable version printed:

Warning: Undefined array key "email" in D:\Final.php on line 29

Risk:

- Exposes internal architecture
- Reveals directory structure
- Aids LFI/RFI, exploitation, recon

Secure Version Status:

- Errors suppressed
- Logged internally only
- Generic error responses returned

→ Fixed

4.3 Hidden Field Manipulation (IDOR) (High)

Evidence: Hidden fields:

doctor_id = 14, appointment_date = 2025-11-29, appointment_time = 10 : 00

Users could modify doctor id via browser devtools or API tools.

Impact:

- Book appointments with any doctor
- Access doctor schedule without authorization
- Break business logic

Secure Version Fix:

- server-side validation of doctor_id
- user-doctor relationship verified
- unauthorized values rejected

→ Fixed

4.4 Race Condition Appointment Spamming (Critical)

Description: Attackers could bypass the “max 3 appointments limit” by issuing parallel POST requests.

Impact:

- Denial-of-service
- Doctor schedule flooding
- Resource exhaustion

Secure Version Fix:

- atomic backend checks
- queueing of appointment writes
- per-user locking

→ Fixed

4.5 Broken Database Integrity / Foreign Key Exceptions (High)

Evidence: Integrity constraint violation: 1452 Cannot add or update a child row

Impact:

- Database schema leakage
- Unhandled exceptions
- Appointment logic failure

Secure Version Fix:

- Pre-insert validation
- Exception handling
- Database-level constraints respected

→ Fixed

4.6 Missing Input Validation (Medium)

Undefined array key warnings revealed backend accepted empty or missing POST fields.

Impact:

- Data inconsistency
- Logic bypass
- Potential injection vectors

Secure Version Fix:

- Required fields enforced
- Sanitization added
- Backend strictly validates JSON/POST

→ Fixed

4.7 XSS Injection Points (High)

User-controlled fields were reflected in the HTML without escaping.

Impact:

- Session hijacking
- Unauthorized actions
- Stealth data alteration

Secure Version Fix:

- htmlspecialchars() applied
- Escaped output
- Input sanitation filters

→ Neutralized

5. Vulnerable vs Secure System: Comparative Analysis

Security Control	Vulnerable System	Secure System
Server-Side Validation	Absent	Implemented
Input Sanitization	Weak	Strong
SQL Injection Protection	None	Prepared statements
Error Handling	Visible errors	Internal logging only
Business Logic Security	Weak	Hardened
Race Condition Protection	None	Backend locking
Hidden Field Trust	Trusted client	Server trust only
XSS Protection	No escapes	Proper escaping

6. Overall Risk Rating

Before Fixes:

- Critical Risk — System Easily Compromised

After Fixes:

- Low to Moderate Risk — Meets Standard Practices

7. Recommendations

High Priority

- Maintain strict backend validation
- Continue using prepared statements
- Enforce rate limiting on critical endpoints
- Perform periodic penetration testing

Medium Priority

- Add WAF protection
- Implement logging & SIEM monitoring

Low Priority

- Add CAPTCHA to reduce automated abuse

8. Final Conclusion

The vulnerable version of the Hospital Management System contained multiple critical flaws, including time-based SQL injection, IDOR vulnerabilities, race conditions, hidden field tampering, and full server path disclosure. The secure version successfully addressed all detected vulnerabilities through:

- Proper backend validation
- Secure database handling
- Improved error handling
- Strengthened business logic
- Client–server isolation principles

Hello Omar Magdy Elkhazendar (Your Clickworker ID: 24501733)
 Account balance € 5.01
 € 3.00 Payable

Job History

Work Item # Job Title State Period ➔

Work Item #	Job Title	Submitted at	State	Amount
460035763	Help train an authentication application (Mobile)	21 Nov 25, 12:18	Completed	EUR 1.00
460049189	Help train an authentication application (Desktop)	21 Nov 25, 11:58	Completed	EUR 2.00
460025713	api.test	20 Nov 25, 10:42	Completed	EUR 2.00
460610457	CPX Research: Interesting surveys!		Timed out	EUR 0.00
460610541	BitLabs: Short and exciting surveys!		Timed out	EUR 0.00
460633993	MyChips: Fun game tests!		In Process	EUR 0.00

per page: [25](#) | [50](#) | [100](#)

Book Appointment - Patient

localhost/DEPI_Final/Vulnerable/Info/patient/appointments.php?success=1

LIMIT REACHED

Hidden field [doctor_id] 14

Hidden field [appointment_date] 2025-11-29

Hidden field [appointment_time] 10:00

Hidden Book (Race Condition)

You have reached the maximum limit of 3 appointments. Please cancel some appointments to book new ones.

Note: The form is disabled in the frontend, but the backend still accepts appointments via direct POST requests.

Upcoming Appointments

Date & Time	Doctor	Specialization	Status	Action
2025-11-29 10:00:00	kareem	General Medicine	Scheduled	Cancel
2025-11-29 10:00:00	kareem	General Medicine	Scheduled	Cancel
2025-11-29 10:00:00	kareem	General Medicine	Scheduled	Cancel

Hidden field [doctor_id]	14
--------------------------	----

Hidden field [appointment_date]	2025-11-29
---------------------------------	------------

Hidden field [appointment_time]	10:00
---------------------------------	-------

Hidden Book (Race Condition)

You have reached the maximum limit of 3 appointments. Please cancel some appointments to book new ones.

Note: The form is disabled in the frontend, but the backend still accepts appointments via direct POST requests.

Upcoming Appointments

Date & Time	Doctor	Specialization	Status	Action
2025-11-29 10:00:00	kareem	General Medicine	<button>Scheduled</button>	<button>Cancel</button>
2025-11-29 10:00:00	kareem	General Medicine	<button>Scheduled</button>	<button>Cancel</button>
2025-11-29 10:00:00	kareem	General Medicine	<button>Scheduled</button>	<button>Cancel</button>

